

## UpWind Guard — Gmail Add-on for Malicious Email Detection

**Architecture** Gmail Add-on (Google Apps Script) extracts email headers, body, and attachments, sends them to a Python Flask backend hosted on Railway. The backend runs 5 analyzers in parallel (LLM on a separate thread), feeds signals into an OWASP-based scoring engine, and returns a verdict displayed in Gmail's sidebar.

### Implemented Features

- Email Authentication Analysis — SPF/DKIM/DMARC parsing with DMARC policy.
- Domain & Reply-To Mismatch Detection — Return-Path vs From, Reply-To vs From, subdomain-aware
- Link Analysis — IP-based URLs, URL shorteners, suspicious TLDs (.tk, .xyz, .ru, etc.)
- Attachment Analysis — Dangerous extensions (.exe, .bat, .ps1), macro files (.xlsm, .docm), double extensions
- AI Content Analysis — Gemini 2.5 Flash detects urgency, social engineering, classifies attack type with confidence %
- LLM Fallback Chain — 3 API keys x 2 models, then regex-based fallback for graceful degradation.
- OWASP Scoring Engine — Likelihood (5 factors) x Impact (2 factors) mapped through 3x3 severity matrix.
- Human-Readable UI — Plain English findings, color-coded verdict, actionable recommendations

**Scoring: Adapted OWASP Risk Rating** Likelihood (0-9) = average of: auth score, domain mismatch, reply-to mismatch, link signals, LLM classification. Impact (0-9) = average of: data compromise + availability loss (both scored by attack type, overridden by dangerous attachments). Both categorized into LOW/MEDIUM/HIGH and looked up in a severity matrix → Note, Low, Medium, High, Critical. A likelihood floor ensures phishing emails from legitimate servers don't score artificially low.

**APIs & Technologies** Google Apps Script, Google CardService API, Python Flask, Google Gemini 2.5 Flash, Railway.

### Key Design Decisions

- Matrix-based severity over linear thresholds — handles edge cases better
- Parallel LLM execution — total time = LLM time (3-5s), not sum of all analyzers
- Dual signal fields (technical + user-facing) — users see plain English, logs keep details.

## Limitations

- Free-tier LLM quota limits throughput (mitigated by multi-key fallback chain)
- No external enrichment APIs yet (VirusTotal, WHOIS, domain age)
- Extension-based attachment analysis only, no sandboxing
- Non-English emails depend on LLM; regex fallback is English-only
- Not implemented: user blacklist, scan history, management console

## File Structure

upwind-guard/

```
|— addon/src/
|  |— api.gs
|     |— appsscript.json
|     |— config.gs
|     |— email_parser.gs
|     |— ui.gs
|— backend/
|     |— .env
|     |— attachment_analyzer.py
|     |— auth_analyzer.py
|     |— domain_analyzer.py
|     |— fallback_analyzer.py
|     |— link_analyzer.py
|     |— llm_analyzer.py
|     |— main.py
|     |— prompt.txt
|     |— requirements.txt
|     |— scorer.py
|     |— test.py
|— README.pdf
```